

Audit Trail Record

Prompts and raw GenAI outputs — pre-production risk register and threat model

Field	Value
System under review	Contoso Customer Onboarding Assistant — GenAI conversational system for retail banking customer onboarding (identity verification, product selection, account setup)
Purpose of this record	Audit trail for the drafting phase. Captures the exact prompts issued to the Guided Scenario Simulation environment and the unedited outputs returned, so that the corrections applied at evaluation can be traced to their source.
Analyst role	AI Governance Analyst
Frameworks in use	NIST AI Risk Management Framework (AI RMF 1.0) — risk register. STRIDE — threat model.
Data sensitivity in scope	Confidential (PII) and Highly Confidential (regulated financial data)
Environment	Guided Scenario Simulation environment (Claude, Cowork session)
Model ID (configured)	claude-opus-5. The model serving any individual request may differ; this is the configured identifier, not an observed one.
Prompt structure	CTCV — Context, Task, Constraints, Verification ask
Date of generation	25 August 2026 (Asia/Kuala_Lumpur)
Record status	Raw. No content in Section 2 has been corrected, and nothing in it should be treated as validated.

Scope note

The scenario brief supplied with this engagement (v1.2-Pilot) documents an HR employee-onboarding assistant. The system under review here is the retail banking customer onboarding assistant defined in the Chief Risk Officer's tasking. The brief has been treated as a reference model only. Boundary facts used in the prompts below are drawn from the tasking, not from the brief, and are therefore not yet supported by an approved document.

Rendering note

Outputs in Section 2 were returned as markdown tables. They are reproduced here as Word tables for legibility. Column order, cell content, wording, and the verification sections are unaltered. No other change has been made.

Section 1 — Prompts Used

The full text of each prompt issued to the Guided Scenario Simulation environment, reproduced verbatim. Each is structured to the CTCV framework: Context, Task, Constraints, Verification ask.

Prompt 1 — AI Risk Register (NIST AI RMF)

Objective Five risk register entries, R-05 to R-09, spanning the data, model, and usage domains.

Framework NIST AI Risk Management Framework (AI RMF 1.0)

Corresponding output Section 2, Output 1

CONTEXT

You are acting as an AI Governance Analyst at Contoso Financial Services. You are drafting pre-production risk documentation for the Contoso Customer Onboarding Assistant: a generative AI conversational system that guides new retail banking customers through identity verification, product selection, and account setup.

Framework in use: NIST AI Risk Management Framework (AI RMF 1.0). Use only its four core functions - GOVERN, MAP, MEASURE, MANAGE.

Data sensitivity. The system ingests, in every session: full legal name; government-issued ID number; date of birth; residential address; employment status; declared annual income. Two sensitivity labels are in scope: Confidential (PII) and Highly Confidential (regulated financial data).

Binding data constraints:

(a) No PII or regulated financial data may be transmitted to external services, partner APIs, or unmanaged LLM endpoints. All inference must remain within the tenant boundary.

(b) Session data may be retained for a maximum of 90 days. Indefinite retention is not permitted.

Deployment environment: Azure OpenAI (GPT-4o) as the staging LLM; Microsoft Purview as the DLP and data governance layer; Azure AI Content Safety as the input/output filter and prompt-injection protection layer.

TASK

Produce exactly five new risk register entries, numbered R-05 through R-09, extending an existing register that already contains R-01 through R-04.

Distribute the five entries across three domains: two DATA entries, two MODEL entries, one USAGE entry.

Return a single markdown table with exactly these ten columns in this order:

Risk ID	NIST Function	Risk Category	Risk Description / Scenario	Likelihood (1-5)	Impact (1-5)	Inherent Score	Mitigation Controls	Residual Score	Risk Owner
---------	---------------	---------------	-----------------------------	------------------	--------------	----------------	---------------------	----------------	------------

Column rules:

- NIST Function: exactly one of GOVERN, MAP, MEASURE, MANAGE - the function under which the risk is primarily addressed.
- Risk Category: choose from - Data Protection & Boundary Integrity; Data Lifecycle & Retention; Model Reliability & Grounding; Adversarial Manipulation & Excessive Agency; Fairness, Transparency & Human Oversight.
- Inherent Score: state as "L x I = N".
- Residual Score: state the post-control likelihood and impact you used, in the form "L x I = N", so the derivation is auditable. Do not state a residual score without showing its derivation. If no control set can be confirmed, state that the residual cannot be derived.
- Risk Description / Scenario: one to two sentences, concrete and testable. Name the specific data class or system component involved.
- Mitigation Controls: name only controls achievable within the deployment environment above. Where a control depends on a specific product configuration, name the configuration.
- Risk Owner: a role title, never a person.

CONSTRAINTS

- Use NIST AI RMF vocabulary only. Do not introduce terminology from NIST CSF (Identify / Protect / Detect / Respond / Recover), PASTA, FAIR, ISO 31000, or OCTAVE. Do not use "tier" or "profile" other than as AI RMF defines them.
- Do not use STRIDE category names anywhere in this output.
- Do not duplicate the subject matter of the existing entries: R-01 product-term hallucination; R-02 prompt injection causing data exfiltration; R-03 product-steering bias; R-04 users mistaking the assistant for a human advisor.
- Do not invent Contoso policies, control names, system components, regulations, or figures that are not stated in CONTEXT. If a control or authority is needed but has not been supplied, say so rather than naming a plausible substitute.
- Do not cite regulation section numbers, penalty amounts, or dates unless they appear in CONTEXT.
- Maximum 60 words per cell in the Risk Description and Mitigation Controls columns.
- Output the table only, followed by the verification sections below. No preamble, no executive summary, no closing recommendations.

VERIFICATION ASK

After the table, provide three separately headed lists.

1. ASSUMPTIONS MADE - every assumption you relied on that is not stated in CONTEXT. Include, at minimum: any allocation of the six data classes to the two sensitivity labels; any control you assumed already exists in the environment; any organisational role you assumed exists.
 2. CONFIDENCE AND UNCERTAINTY - for each of the five entries, state high, medium, or low confidence and one sentence on what drives that rating. Be explicit wherever a Likelihood or Impact rating is an unsupported estimate rather than a data-backed one.
 3. INFORMATION NOT AVAILABLE TO ME - what you would need in order to raise confidence: specific documents, configurations, measurements, or decisions. Do not attempt to fill these gaps yourself.
- Do not soften, merge, or omit items in these three lists in order to make the output appear more complete than it is.

Prompt 2 — STRIDE Threat Model (Inference Endpoint)

Objective Eight STRIDE threats scoped to the inference endpoint and its immediate data path.

Framework STRIDE

Corresponding output Section 2, Output 2

CONTEXT

You are acting as an AI Governance Analyst at Contoso Financial Services, producing a pre-production threat model for the Contoso Customer Onboarding Assistant: a generative AI conversational system that guides new retail banking customers through identity verification, product selection, and account setup.

Framework in use: STRIDE. Use only the six STRIDE categories - Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege.

Data sensitivity. Every session ingests: full legal name; government-issued ID number; date of birth; residential address; employment status; declared annual income. Sensitivity labels in scope: Confidential (PII) and Highly Confidential (regulated financial data). No PII or regulated financial data may reach external services, partner APIs, or unmanaged LLM endpoints; all inference must remain within the tenant boundary. Session data retention is capped at 90 days.

Scope of this threat model - the inference endpoint and its immediate data path:

- C-1 Client channel (unauthenticated onboarding session)
- C-2 Session / orchestration service (prompt assembly, conversation state)
- C-3 Azure AI Content Safety - input filter and prompt-injection shield
- C-4 Retrieval layer - vector store of product terms, rate sheets, disclosures
- C-5 Azure OpenAI GPT-4o inference endpoint
- C-6 Azure AI Content Safety - output filter
- C-7 Microsoft Purview DLP and governance plane
- C-8 Downstream action interface - identity-verification service and core banking account-opening API
- C-9 Logging, telemetry and audit store
- C-10 Secrets and workload identity plane

Trust boundaries:

- TB-1 Unauthenticated internet to orchestration (C-1 to C-2)
- TB-2 Orchestration to Azure OpenAI (C-2 to C-5)
- TB-3 Orchestration to retrieval corpus (C-2 to C-4)
- TB-4 Model / orchestration to identity verification and core banking (C-2 to C-8)
- TB-5 In-tenant processing to logging, telemetry and analytics (C-2 to C-9)

Out of scope: model training and fine-tuning pipelines, CI/CD infrastructure, physical and datacentre controls, corporate identity-provider internals.

TASK

Produce exactly eight threats. Cover all six STRIDE categories, with at least one threat per category.

Prioritise the trust boundaries that the existing worksheet does not model. The existing worksheet covers only C-4 and C-5; TB-1, TB-2, TB-4 and TB-5 are unmodelled.

Return a single markdown table with exactly these eight columns in this order:

Threat ID | Threat Category | System Element | Trust Boundary | Specific Threat Scenario | Existing / Proposed Countermeasures | Status | Linked Risk ID

Column rules:

- Threat ID: T-01 through T-08.
- System Element: cite the component ID (C-1 to C-10) and its name.
- Trust Boundary: cite the boundary ID (TB-1 to TB-5).
- Specific Threat Scenario: one to two sentences naming the actor, the action, and the asset affected. Make it concrete enough to test.
- Status: use exactly one of - "Mitigated - evidence cited"; "Mitigated - asserted"; "Open / In Progress"; "Open / Review Required". Use "Mitigated - evidence cited" only if you can name the verification method that produced the evidence. If you cannot, use "Mitigated - asserted".

- Linked Risk ID: the risk register entry this threat maps to (R-01 to R-09). If no existing entry covers it, write "No register entry - gap".

CONSTRAINTS

- Use STRIDE vocabulary only. Do not introduce terminology from PASTA, NIST CSF, NIST AI RMF, MITRE ATT&CK, DREAD, or cyber kill chain. Do not assign DREAD or CVSS scores.
- Do not carry over controls that do not apply to this system. In particular, corporate SAML SSO does not apply at C-1: onboarding applicants are unauthenticated members of the public.
- Do not invent components, vendors, product names, or configurations beyond those listed in scope. If a countermeasure depends on something not listed, say so.
- Do not mark a threat "Mitigated" on the basis of a control that is proposed rather than implemented.
- Maximum 60 words per cell in the Scenario and Countermeasures columns.
- Output the table only, followed by the verification sections below. No preamble and no summary.

VERIFICATION ASK

After the table, provide three separately headed lists.

1. ASSUMPTIONS MADE - every assumption not stated in CONTEXT, including any assumed architecture behaviour, any assumed existing control, and any assumed property of a listed component.
 2. CONFIDENCE AND UNCERTAINTY - for each of the eight threats, state high, medium, or low confidence and one sentence on what drives it. Be explicit where a countermeasure is proposed rather than known to exist.
 3. INFORMATION NOT AVAILABLE TO ME - the documents, diagrams, configurations, or test results you would need to raise confidence. Do not fill these gaps yourself.
- Do not omit a threat category, and do not downgrade an "Open" status to "Mitigated" in order to make the worksheet look more complete.

Section 2 — Raw GenAI Outputs

Unedited output returned by the Guided Scenario Simulation environment, labelled to correspond with the prompt that generated it. Nothing below has been corrected, reordered, or filtered. Errors, unsupported ratings, and unresolved gaps are retained deliberately — they are the input to the evaluation step, not a defect in this record.

Output 1 — Response to Prompt 1 (AI Risk Register)

Generated by Guided Scenario Simulation environment — configured model claude-opus-5 | Generated on 25 August 2026 | Status: RAW — UNEDITED

Risk register entries R-05 to R-09

Risk ID	NIST Function	Risk Category	Risk Description / Scenario	Likelihood (1-5)	Impact (1-5)	Inherent Score	Mitigation Controls	Residual Score	Risk Owner
R-05	MANAGE	Data Protection & Boundary Integrity	Azure OpenAI abuse-monitoring retains prompt and completion content containing government-issued ID numbers and declared annual income for service-side review, placing Highly Confidential data outside the controlled processing path even though inference itself remains in-tenant.	3	5	3 x 5 = 15	Apply for and enable the Azure OpenAI modified content filtering / abuse monitoring exemption; verify the no-content-logging configuration on the deployment; Purview policy at the orchestration service to withhold Highly Confidential classes from the prompt payload on turns that do not require them.	2 x 5 = 10	Cloud Security Architect
R-06	GOVERN	Data Lifecycle & Retention	Vector embeddings, cached conversation context, and Content Safety filter logs derived from session PII persist beyond the 90-day boundary because deletion is implemented only against the primary transcript store.	4	4	4 x 4 = 16	Extend the retention schedule to every derived store; use the Purview data map to inventory derived copies; automated deletion job with per-store completion attestation; assessment of embedding reversibility to confirm embeddings are treated as personal data.	2 x 4 = 8	Data Governance Lead
R-07	MANAGE	Adversarial Manipulation & Excessive Agency	Indirect prompt injection embedded in a retrieved product-disclosure document causes the assistant to invoke the downstream account-opening interface and complete account setup without a passed identity-verification result.	3	5	3 x 5 = 15	Enforce verification state deterministically server-side, outside the model; treat all model output directed at the account-opening interface as untrusted input; allow-list of permitted downstream actions with parameter validation; extend Content Safety prompt shields to retrieved document content, not user input alone.	2 x 5 = 10	Application Security Lead
R-08	MEASURE	Model Reliability & Grounding	A GPT-4o model version update alters grounding and refusal behaviour for product-eligibility questions, degrading accuracy after the pre-production evaluation baseline was established, with no revalidation triggered.	4	3	4 x 3 = 12	Pin the model version on the deployment; subscribe to model change notifications; re-run the regression evaluation suite as a mandatory release gate on any version change; bind Model_ID to every logged request so drift can be attributed.	2 x 3 = 6	AI Platform / MLOps Lead

Risk ID	NIST Function	Risk Category	Risk Description / Scenario	Likelihood (1-5)	Impact (1-5)	Inherent Score	Mitigation Controls	Residual Score	Risk Owner
R-09	MAP	Fairness, Transparency & Human Oversight	Automated identity-verification false-reject rates differ across applicant groups, so some customers are excluded from account opening with no documented human review path and no reason recorded at the point of rejection.	3	4	3 x 4 = 12	Cannot be fully specified from the information supplied. Requires a stated human-in-the-loop policy for verification failures, disaggregated false-accept and false-reject measurement, and reason capture at rejection. I have not been given the verification component, its vendor, or any performance data.	Cannot be derived - no confirmed control set	Fair Lending Officer

ASSUMPTIONS MADE

1. Sensitivity label allocation. CONTEXT names two labels but does not allocate the six data classes between them. I assumed government-issued ID number and declared annual income are Highly Confidential, and full legal name, date of birth, residential address, and employment status are Confidential. Several controls in R-05 depend on this allocation.
2. Azure OpenAI abuse monitoring. I assumed the default service configuration retains prompt and completion content for a period and permits limited service-side review unless an exemption is approved. I have not verified this against current product documentation and it is subject to change by the vendor.
3. Downstream write capability. CONTEXT says the assistant supports "account setup" but does not describe an integration. R-07 assumes the assistant can trigger a real account-creation action in a downstream system. If it only drafts an application for human submission, R-07's Impact rating is too high.
4. Automated identity verification. I assumed identity verification is performed by or with an automated component capable of rejecting an applicant. CONTEXT does not say this.
5. Retrieval architecture. I assumed embeddings are generated and persisted in a vector store. CONTEXT does not name a retrieval layer; R-06 and R-07 both depend on one existing.
6. Organisational roles. Cloud Security Architect, Data Governance Lead, Application Security Lead, AI Platform / MLOps Lead, and Fair Lending Officer are assumed to exist at Contoso. None are stated in CONTEXT.
7. Existing register content. I have not seen R-01 to R-04. I relied on the one-line descriptions given in the CONSTRAINTS section to avoid duplication, which may not reflect their full scope.
8. Purview configuration. CONTEXT states Purview is present but not how it is configured. I assumed classifiers exist for the six data classes and that policies can be applied at the orchestration layer.
9. Scoring scale. No anchor definitions were supplied for Likelihood or Impact. I applied an unanchored 1-5 judgement, which is not comparable to R-01 to R-04 unless those used the same interpretation.

CONFIDENCE AND UNCERTAINTY

- R-05 - Medium. The mechanism is well understood and the constraint it violates is stated explicitly in CONTEXT, but the risk hinges entirely on a vendor configuration I cannot inspect. If the exemption is already approved for this tenant, the entry is materially overstated.
- R-06 - High on mechanism, low on ratings. Failure to cascade deletion to derived stores is a common and well-documented failure mode. The Likelihood of 4 is my estimate; I have no Contoso deletion-testing data to support it.
- R-07 - High on mechanism, medium overall. Indirect injection through retrieved content is well established. The Impact of 5 rests on assumption 3; if the assistant cannot actually create accounts, this should drop.
- R-08 - Medium. Version drift is real and the control set is standard, but the Likelihood of 4 is unsupported and depends on whether the deployment already pins versions, which I was not told.
- R-09 - Low. This is the weakest entry in the set. I have no fairness measurement data, no named verification component, and no stated review policy. The Likelihood and Impact figures are placeholders and should not be relied on until measured. I have deliberately left the residual score underderived rather than assert one.

INFORMATION NOT AVAILABLE TO ME

- Contoso Data Classification Standard and the approved allocation of the six data classes to the two sensitivity labels.
- Current Azure OpenAI deployment configuration, including whether a modified content filtering / abuse monitoring exemption is approved for this tenant.
- Purview DLP policy definitions, classifier coverage for the six data classes, and whether policies are in enforce or audit mode.
- Azure AI Content Safety configuration: which filters are enabled, at what thresholds, and whether prompt shields are applied to retrieved documents as well as user input.
- An architecture diagram or data-flow diagram, in particular for the identity-verification and account-opening integration.
- Whether a vector store exists, what it indexes, and its retention configuration.
- The retention floor imposed by the applicable banking record-keeping regulations. CONTEXT cites those regulations as authority for a 90-day cap but states no floor, and the two may conflict.
- The full text and scoring rationale of existing entries R-01 to R-04.

- Contoso's Likelihood and Impact scale anchors, expressed in financial, customer, or regulatory terms.
- Any existing evaluation, red-team, penetration test, or fairness testing results for this system.
- Contoso's RACI or ownership model for AI systems, to confirm the risk owner roles named above exist.

Output 2 — Response to Prompt 2 (STRIDE Threat Model)

Generated by Guided Scenario Simulation environment — configured model claude-opus-5 | Generated on 25 August 2026 | Status: RAW — UNEDITED

STRIDE threats T-01 to T-08

Threat ID	Threat Category	System Element	Trust Boundary	Specific Threat Scenario	Existing / Proposed Countermeasures	Status	Linked Risk ID
T-01	Spoofing	C-1 Client channel	TB-1	An attacker completes onboarding using a stolen identity document and matching static PII, impersonating a real person at the client channel. There is no prior authenticated relationship to verify the applicant against.	Proposed: document liveness and biometric match at the client channel; device and network signal binding; velocity and reuse checks across sessions. Corporate SSO is not applicable here. The verification component is not named in scope, so no existing control can be confirmed.	Open / In Progress	R-09
T-02	Spoofing	C-10 Secrets and workload identity plane	TB-2	A workload credential or API key for the Azure OpenAI endpoint is captured and replayed from outside the orchestration service, allowing an attacker to submit inference requests that appear to originate from the assistant.	Proposed: managed workload identity in place of API keys; private endpoint and network isolation on the inference endpoint; key rotation; egress restriction from the orchestration service. Current credential mechanism is not stated in scope.	Open / Review Required	R-05
T-03	Tampering	C-4 Retrieval layer	TB-3	An actor with write access to the retrieval corpus inserts or alters a product-disclosure document, changing the fee or eligibility terms the model grounds on, so the assistant confidently quotes tampered terms to applicants.	Proposed: write-path RBAC on the vector store; content hashing and signature verification of approved disclosures at index time; periodic reconciliation of indexed content against the source of record.	Open / In Progress	R-01
T-04	Repudiation	C-9 Logging, telemetry and audit store	TB-5	A customer disputes the product terms the assistant stated, but the dispute is raised after the 90-day retention boundary has elapsed, so no transcript survives to adjudicate the claim and the interaction cannot be reconstructed.	Proposed: establish the regulatory retention floor and reconcile it against the 90-day cap; retain the full transcript together with the retrieved-context record for each turn; document a formal carve-out if the floor exceeds the cap. This conflict cannot be resolved from the information supplied.	Open / Review Required	R-06
T-05	Information Disclosure	C-9 Logging, telemetry and audit store	TB-5	Prompt and completion payloads containing government-issued ID numbers and declared annual income are written to application telemetry and analytics sinks outside the controlled data path, because logging is applied at the orchestration layer before DLP classification takes effect.	Proposed: redaction at the orchestration layer before any log write; Purview classification applied to telemetry sinks as well as primary stores; disable payload capture in application performance monitoring; confirm Content Safety and platform diagnostic logs do not persist content.	Open / Review Required	R-05
T-06	Information Disclosure	C-2 Session / orchestration service	TB-2	Conversation context from one applicant session persists in a shared cache or a mis-scoped session key and is included in the prompt assembled for a different applicant, disclosing PII across customers.	Proposed: cache partitioning keyed to session identity; stateless prompt assembly; automated cross-session leakage tests added to the evaluation suite. No current cache design was supplied, so no existing control can be confirmed.	Open / Review Required	R-05
T-07	Denial of Service	C-5 Azure OpenAI GPT-4o inference endpoint	TB-2	Automated high-volume sessions exhaust the deployment's token throughput during a campaign period, denying service to legitimate applicants mid-onboarding and inflating consumption cost.	Proposed: per-session and per-source rate limiting at the client channel; maximum token constraints enforced at the orchestration layer; throughput reservation with burst alerting; bot detection applied before inference is invoked.	Open / Review Required	No register entry - gap

Threat ID	Threat Category	System Element	Trust Boundary	Specific Threat Scenario	Existing / Proposed Countermeasures	Status	Linked Risk ID
T-08	Elevation of Privilege	C-8 Downstream action interface	TB-4	An adversarial prompt causes the assistant to invoke the account-opening API with a product tier or limit the applicant is not eligible for, because eligibility is evaluated inside the model rather than enforced by a downstream service.	Proposed: move eligibility determination out of the model into a deterministic service; allow-list and parameter validation on all downstream calls; require a signed verification-state token; human approval for any tier exception.	Open / Review Required	R-07

ASSUMPTIONS MADE

1. I assumed the account-opening interface at C-8 performs a real write to a core banking system and can be invoked as a result of model output. If the assistant only drafts an application for human submission, T-08 is materially overstated.
2. I assumed the retrieval layer at C-4 has a write path reachable by an internal actor. No ingestion or content-approval process was described.
3. I assumed Content Safety at C-3 is applied to user input only, and not currently to retrieved document content. This is the common default but was not stated.
4. I assumed application telemetry exists at C-9 and captures request payloads by default. No logging configuration was supplied.
5. I assumed the orchestration service at C-2 maintains conversation state across turns, which is what creates the cross-session exposure in T-06. CONTEXT describes prompt assembly and conversation state but not their implementation.
6. I assumed the Azure OpenAI deployment is subject to a throughput or quota limit that can be exhausted. The deployment model was not specified.
7. I assumed no biometric or liveness verification exists today at C-1, since none is listed in scope.
8. I assumed the 90-day retention cap applies to conversation transcripts, which is what makes T-04 a repudiation issue rather than a storage issue.

CONFIDENCE AND UNCERTAINTY

- T-01 - Medium. Synthetic and stolen identity fraud in remote onboarding is well documented, but every countermeasure listed is proposed, and I do not know what verification vendor or method is in place.
- T-02 - Medium. A standard credential-replay threat. Confidence is limited because the current credential mechanism is not in scope; if managed identity is already in use, most of this is already addressed.
- T-03 - High. Retrieval corpus tampering is a well-established threat class and the asset at risk, published product terms, is unambiguous. Countermeasures are proposed, not confirmed.
- T-04 - Low on resolution, high on the existence of the conflict. I am confident the 90-day cap and banking record-keeping obligations are in tension. I cannot say where the boundary should sit, because no retention floor was supplied.
- T-05 - Medium to high. Payload leakage into telemetry is one of the most common ways a stated tenant-boundary constraint is broken in practice. I have no logging configuration to confirm whether it applies here.
- T-06 - Medium. Cross-session context bleed is a real and repeatedly observed failure, but its likelihood depends entirely on the caching and session design, which I was not given.
- T-07 - Medium. The mechanism is straightforward. I have marked the countermeasures as proposed because no rate limiting or bot detection is listed in scope. Note that no risk register entry covers availability or consumption cost; this is a gap in the register, not in the threat model.
- T-08 - High. Excessive agency at the model-to-backend boundary is the highest-consequence threat in this set, and the trust boundary it crosses was not modelled in the existing worksheet at all. Confidence in the mechanism is high; confidence in the impact rests on assumption 1.

INFORMATION NOT AVAILABLE TO ME

- A data-flow diagram for the inference path, showing where PII is held, transformed, and written.
- The identity-verification component: vendor, method, and current false-accept and false-reject performance.
- Whether the orchestration service authenticates to the inference endpoint by managed identity or by key.
- Purview DLP policy scope, and whether it covers telemetry and analytics sinks as well as primary data stores.
- Azure AI Content Safety configuration, including whether prompt shields are applied to retrieved content.
- Application and platform logging configuration, and what is captured by default.
- Session and cache design for conversation state.
- The Azure OpenAI deployment model and any throughput reservation.
- The interface contract for the account-opening API, including what parameters the model can influence.
- The retention floor imposed by applicable banking record-keeping regulations.
- Existing penetration test, red-team, or abuse-testing results for this system.

- The existing STRIDE worksheet rows, so that duplication and status inconsistencies can be reconciled.

End of raw output record. Sections 1 and 2 are closed for amendment. Any correction to the content above is recorded separately at the evaluation step and must cite the output line it revises.